



CLEARANCE: IT INFRASTRUCTURE & SECURITY TEAMS

Security Advisory: Cisco UCS Manager CVE-2026-20037

Vulnerability Intelligence and Remediation Strategy

Executive Summary and Bottom Line Up Front



The Threat

Cisco UCS Manager contains a privilege misconfiguration vulnerability allowing local, local, authenticated attacks.



The Impact

Read-only users can bypass restrictions to access the NX-OS CLI, overwrite files, and execute limited privileged operations.



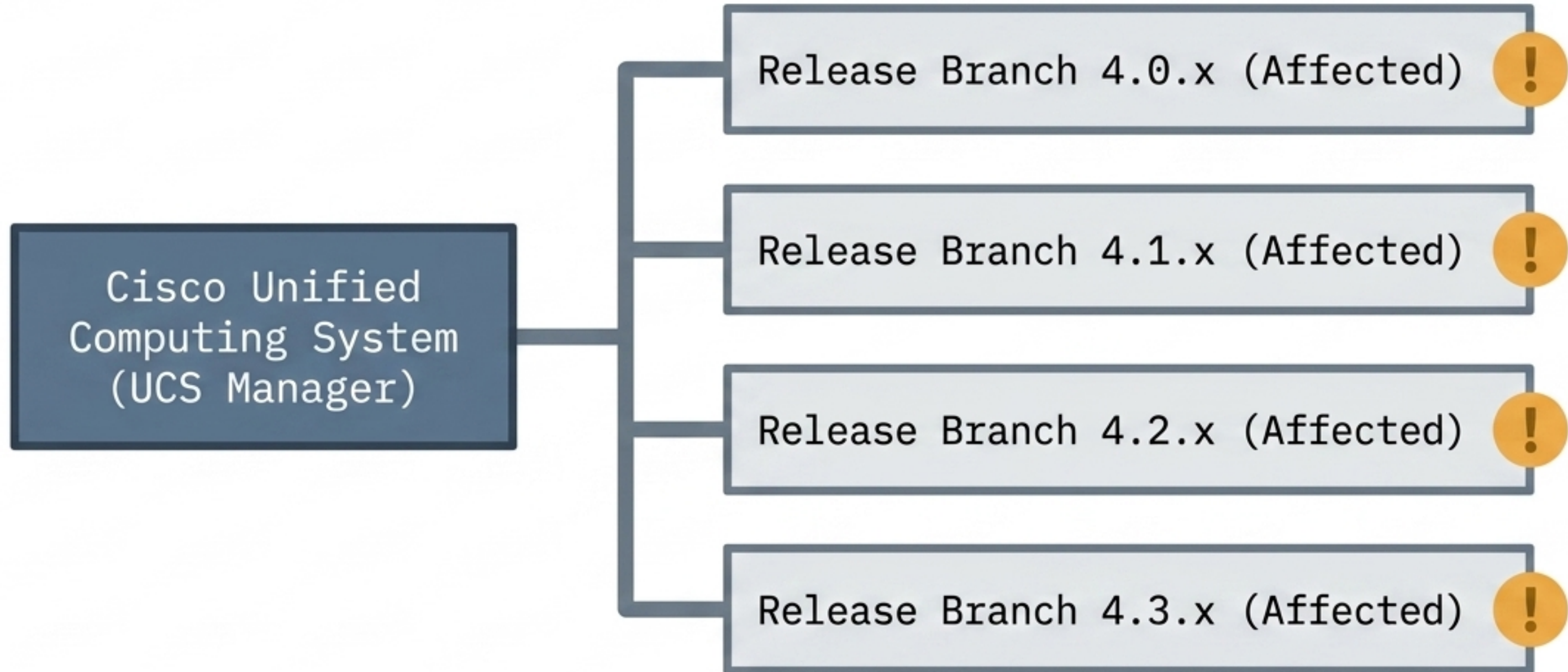
The Action

Audit read-only role-based access controls immediately and schedule upgrades to the Cisco fixed release.

Vulnerability Specification Data

CVE ID	Vendor	Product
CVE-2026-20037	Cisco	Cisco UCS Manager Software
Published Date	Severity	CVSS Score
25 February 2026	Medium	4.4

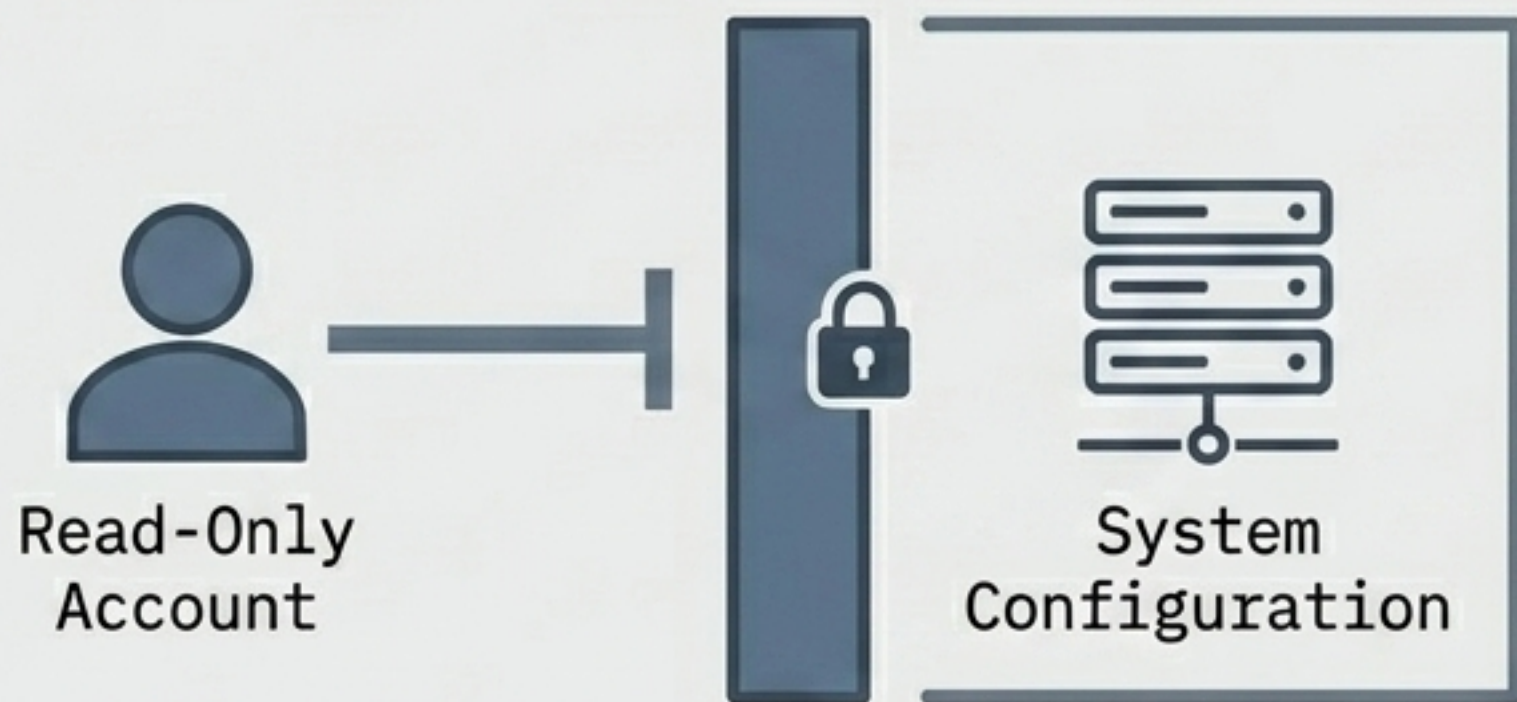
The Affected Ecosystem



Multiple specific releases within these branches contain the vulnerability.

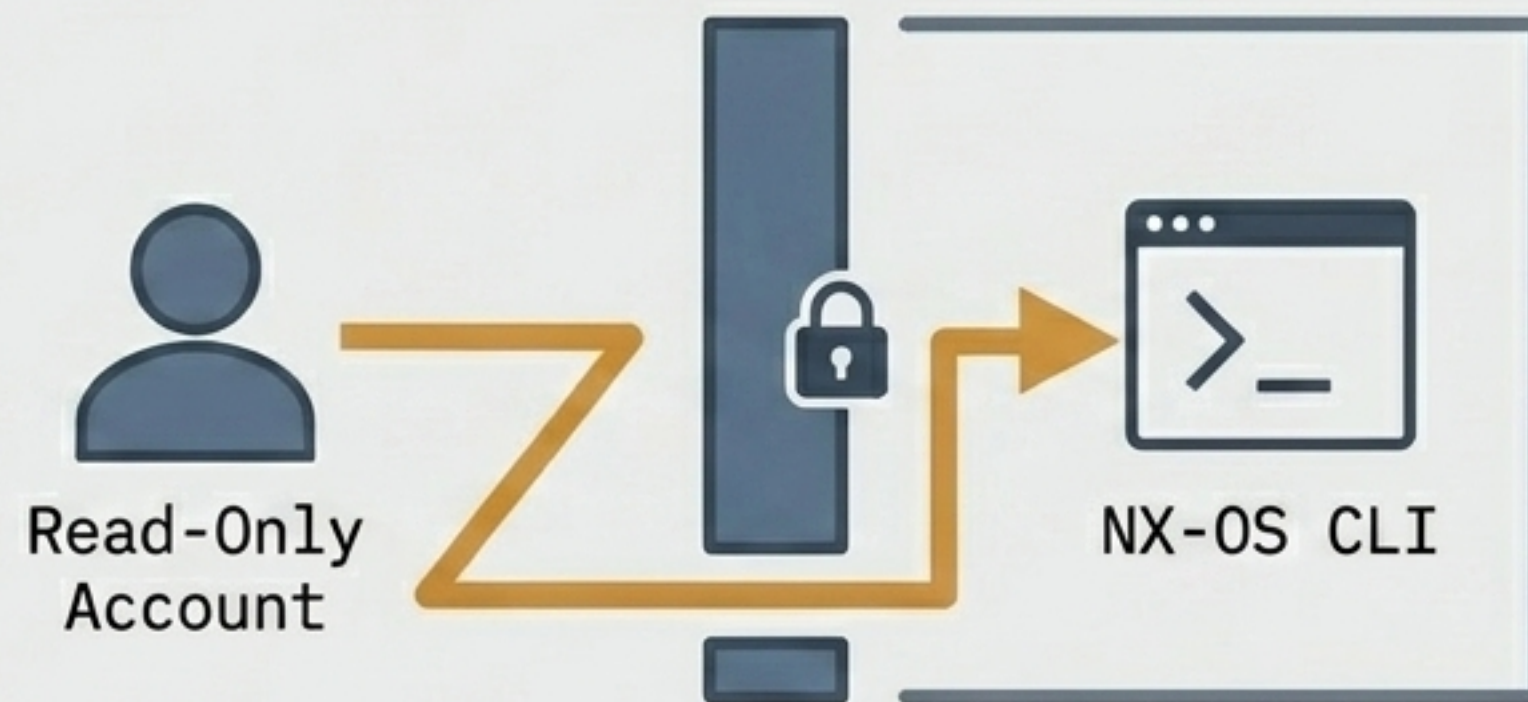
Architectural Root Cause Analysis

Expected RBAC



Read-only accounts should be strictly restricted to viewing system state without modification capabilities.

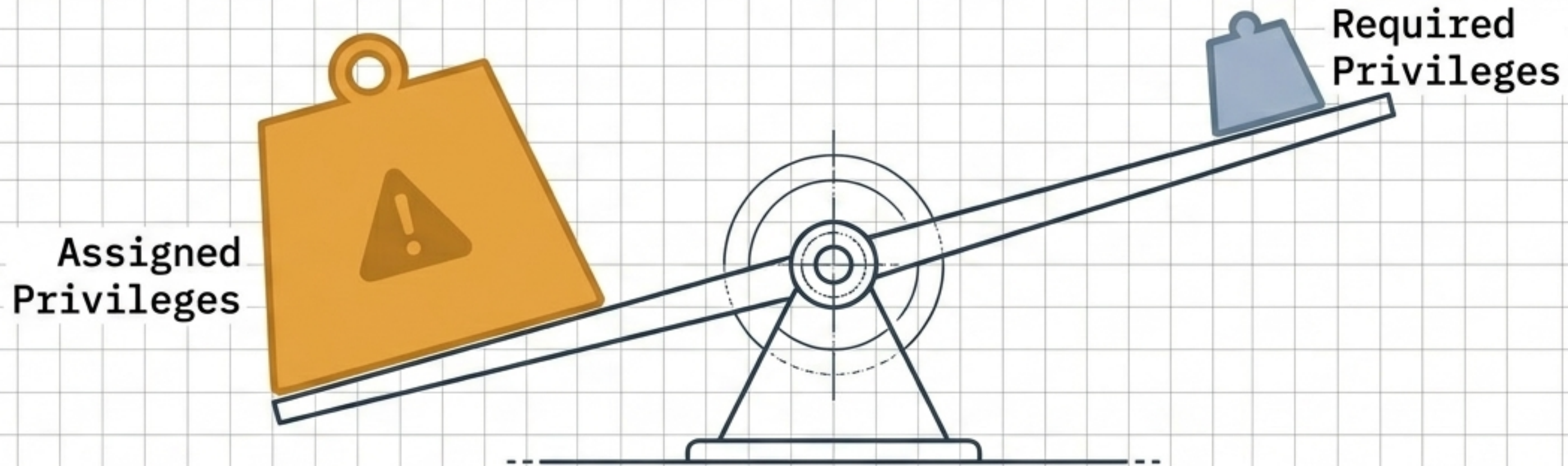
CVE-2026-20037 Bypass



Improper privilege assignment grants read-only accounts access to the NX-OS CLI, allowing file creation and arbitrary overwrites.

Understanding CWE-250

Execution with Unnecessary Privileges



This vulnerability maps directly to **CWE-250**. It occurs when an application performs operations at a privilege level that exceeds what is strictly necessary for the user's role.

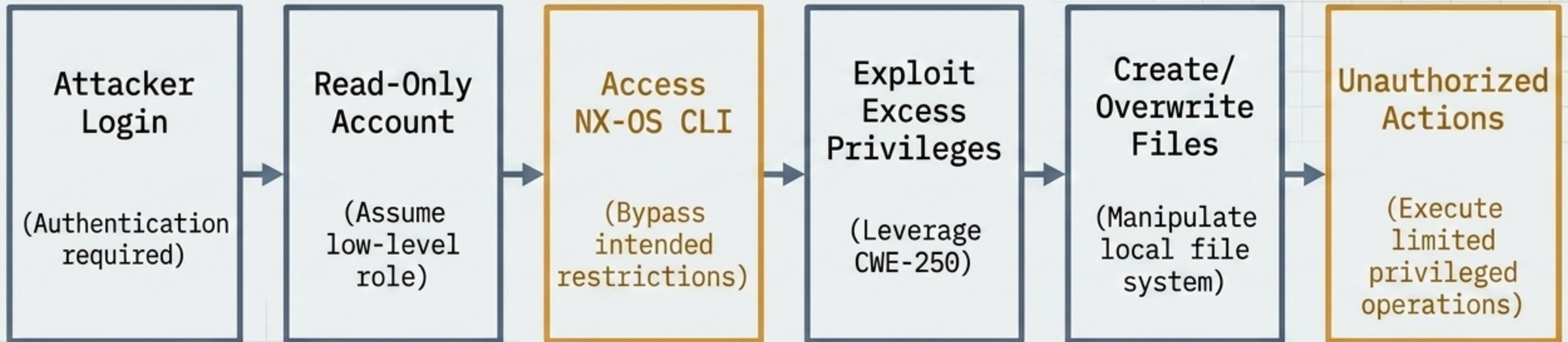
By granting NX-OS CLI access to read-only roles, the system critically violates the foundational **Principle of Least Privilege**.

Exploitation Prerequisites

Required Components	Not Required / Excluded
✓ Valid User Account	✗ Admin Access
✓ Read-Only Privileges	✗ User Interaction
✓ Local Access	✗ Remote Network Exploitation

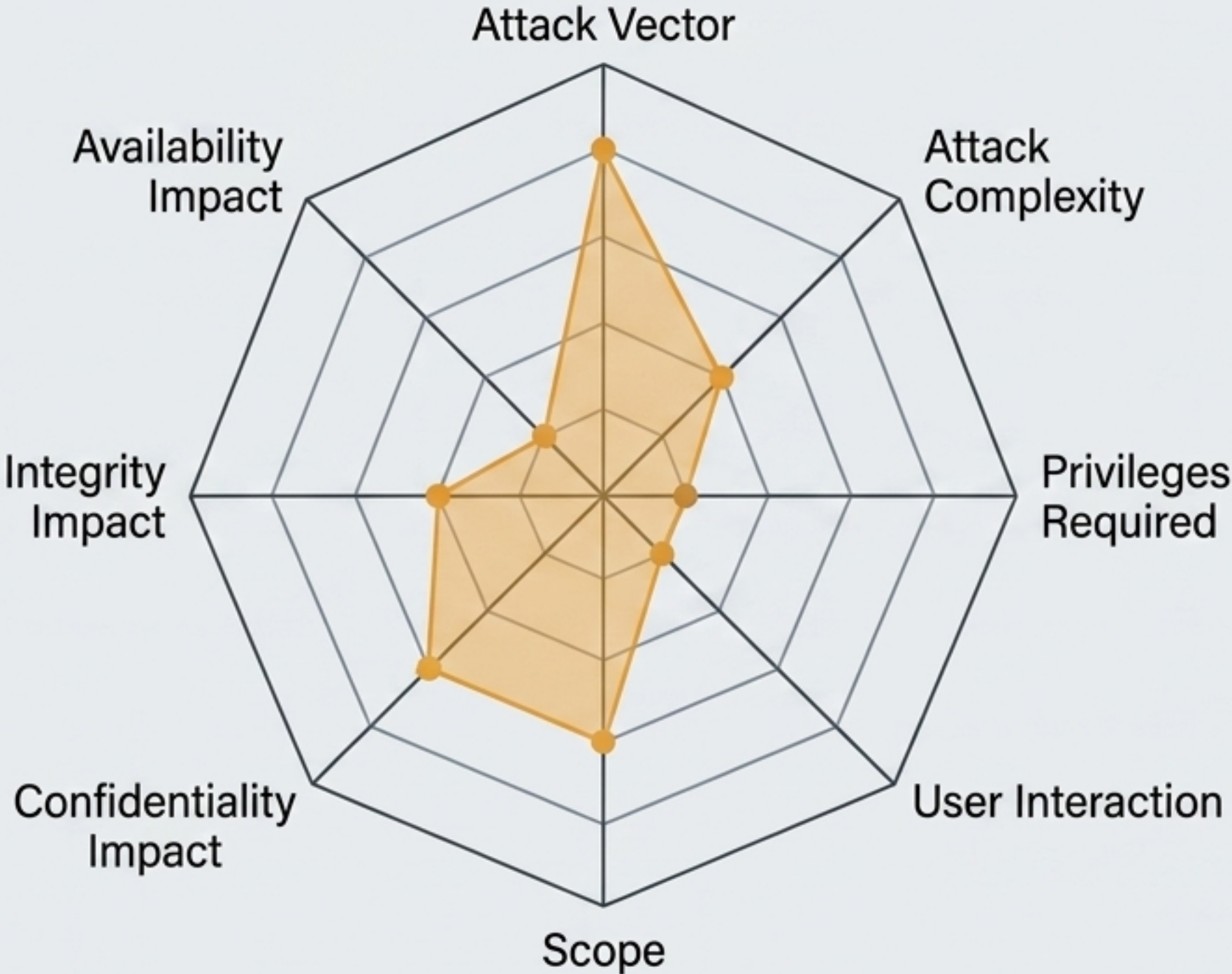
The attack boundary is strictly authenticated and local, severely limiting remote exploitation paths.

The Attack Chain Flow



CVSS 3.1 Vector Analysis

CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N

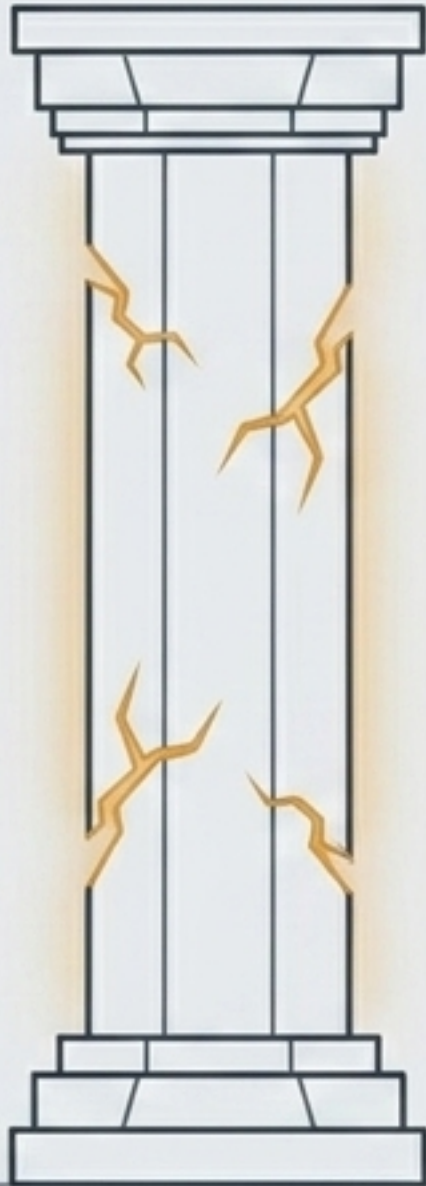


Attack Vector:	Local
Attack Complexity:	Low
Privileges Required:	Low
User Interaction:	None
Scope:	Unchanged
Confidentiality Impact:	Low
Integrity Impact:	Low
Availability Impact:	None

Result Highlight:
CVSS Score 4.4 (Medium Severity)

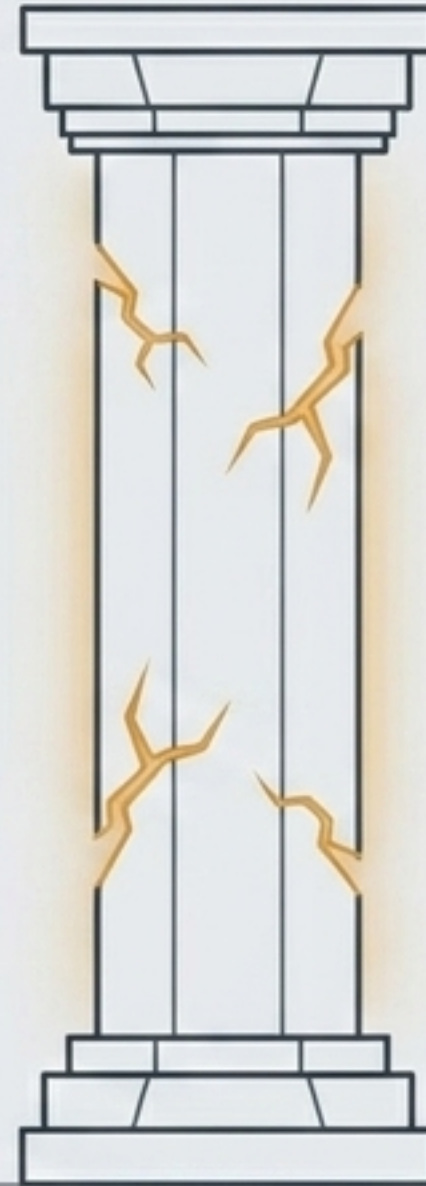
Technical Impact via the CIA Triad

Confidentiality



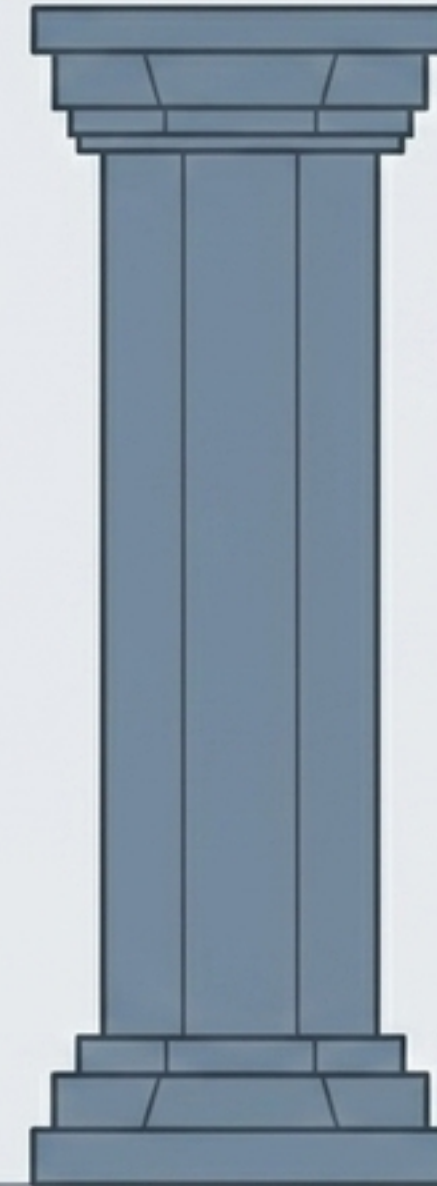
Results in limited exposure of internal system information.

Integrity



Read-only users possess the capability to actively modify or overwrite configuration files.

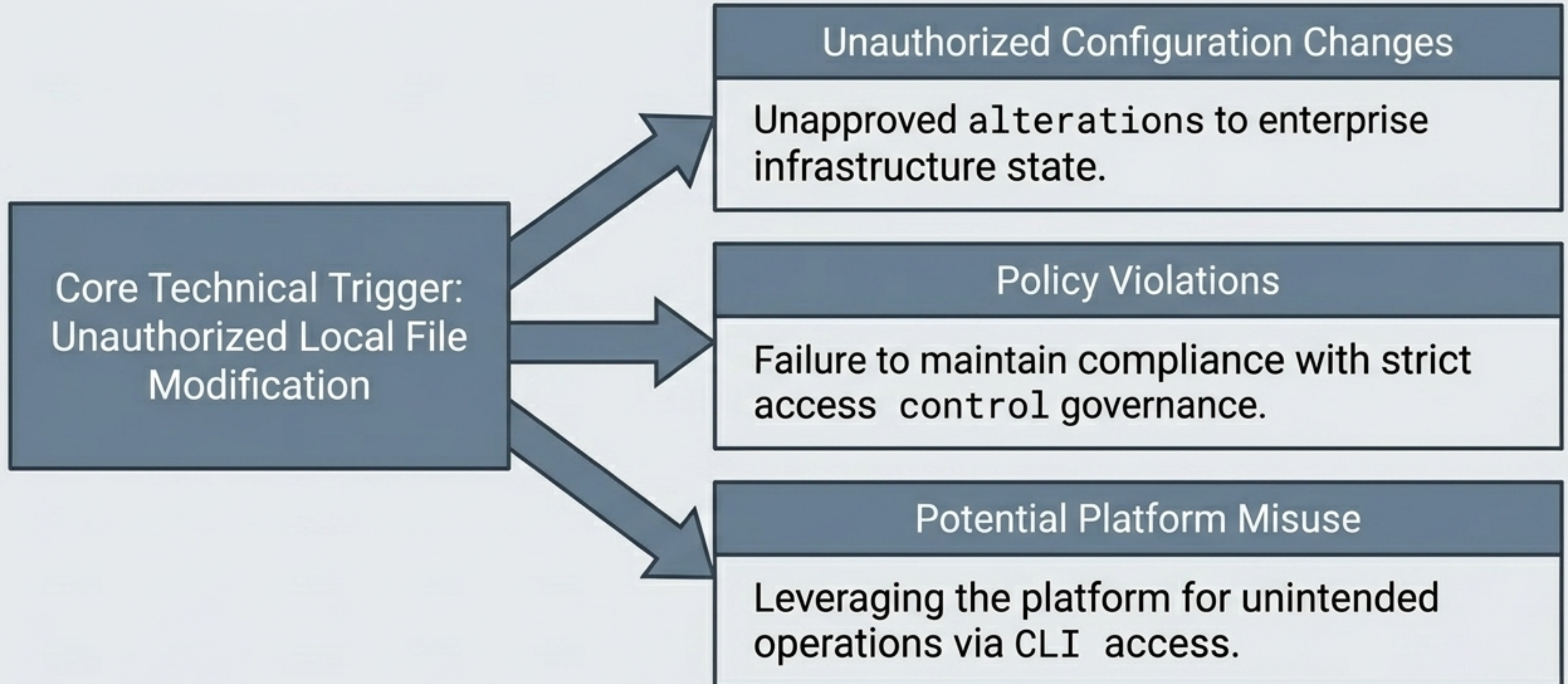
Availability



The vulnerability presents no direct impact to system uptime or resource availability.

Organizational and Business Risk Profile

Overall Risk Rating: Medium



Real-World Threat Landscape Status

Cisco PSIRT Statement

NO Public Exploit Available

NO Active Attacks Reported

NO Known Malicious Exploitation

CISA Assessment

Exploitation:
None

Automatable: No

Technical Impact:
Partial

Mitigation and Remediation Strategy

Immediate Defensive Actions

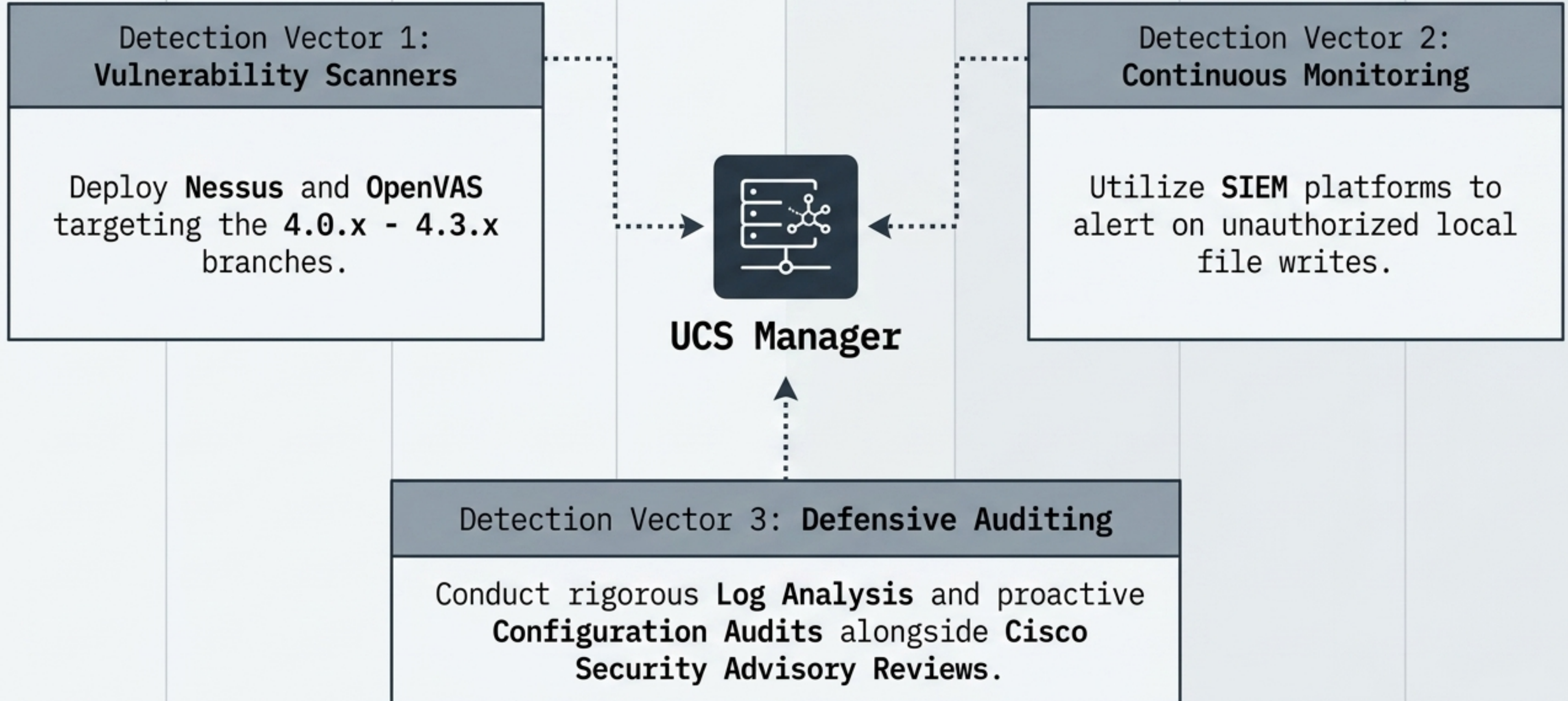
- Review and audit Role-Based Access Controls (RBAC).
- Audit current user permissions for anomalies.
- Restrict CLI access tightly where business operations allow.
- Monitor actively for unauthorized file modifications.



Definitive Resolution

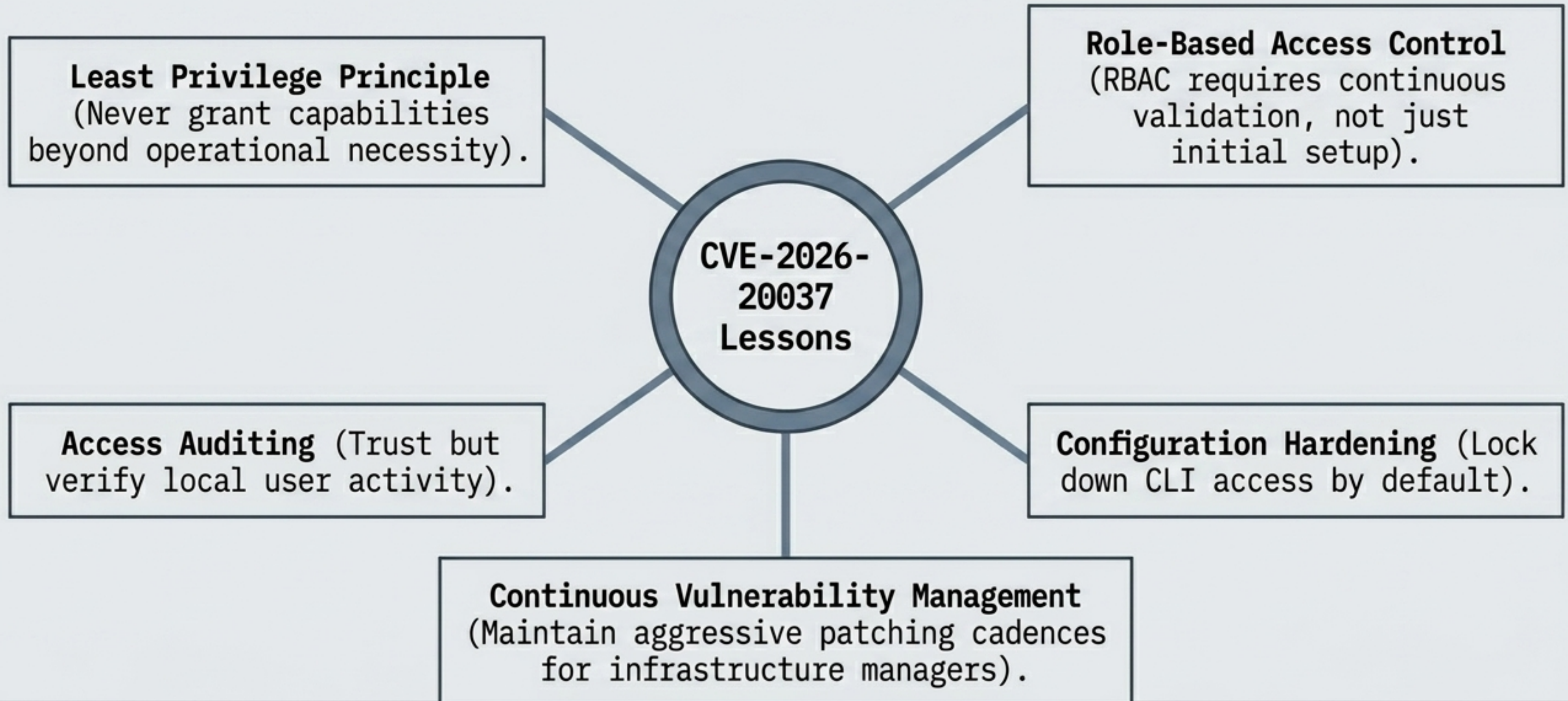
**Upgrade to the
officially patched
Cisco fixed release
for your specific
4.x branch.**

Detection and Auditing Toolkit



Best Practice Synthesis

Using this vulnerability to reinforce foundational security posture.



Briefing Summary and Next Steps

- CVE-2026-20037 is a **Medium severity (4.4)** local file write vulnerability in Cisco UCS Manager.
- Read-only accounts can improperly access the NX-OS CLI.
- No active exploitation currently exists in the wild.

- **Primary Directive:** Schedule firmware updates to the fixed release.
- **Reference:** Consult the official Cisco Security Advisory for specific patch versions corresponding to your current 4.x environment.